

EVALUACIÓN DETALLADA · 2 DE AGOSTO DE 2026

Evaluación de Superficie de Ataque

Example

example.com

88

PUNTAJE DE RIESGO / 100

Crítico

Resumen Ejecutivo

Evaluación de superficie del dominio **example.com** mediante reconocimiento pasivo e inspección de los servicios expuestos públicamente en internet. No se realizaron pruebas de intrusión activa.

1

CRÍTICOS

1

ALTOS

3

MEDIOS

2

BAJOS

Se identificaron debilidades en la configuración de correo del dominio **@example.com** que permiten suplantar el remitente. Se recomienda implementar DMARC con política **p=reject** como prioridad inmediata.

SEGURIDAD DE CORREO ELECTRÓNICO

SPF

SPF con mecanismo permisivo (~all)

⚠ Medio — spoofing parcial posible desde IPs no listadas

v=spf1 include:_spf.example.com ~all

DMARC

no DMARC record

⚠ Crítico — sin protección contra phishing y BEC

ENTREGABILIDAD DE CORREO

El correo saliente del dominio puede ser rechazado o filtrado

⚠ Crítico — correo saliente rechazado o filtrado

TLS CORREO

Servidor mail.ejemplo.cl no usa TLS — correos viajan sin cifrar

⚠ Alto — interceptación de correos en tránsito

mail.ejemplo.cl

MTA-STS

MTA-STS no configurado — TLS no forzado en correos entrantes

⚠ Medio — sin garantía de cifrado en tránsito

Impacto operacional de la configuración de correo. Sin SPF y DMARC correctamente configurados, los servidores de destino pueden rechazar o filtrar el correo saliente de **@example.com**, y un tercero puede enviar correo suplantando el dominio sin que el receptor disponga de una señal técnica para distinguirlo del legítimo.

Este informe fue generado mediante reconocimiento pasivo e inspección de servicios expuestos públicamente. No se realizaron pruebas de explotación activa ni acceso no autorizado a sistemas. Los hallazgos representan riesgos potenciales identificados desde internet, sin autenticación.

Escenarios de Riesgo

Los siguientes escenarios describen cómo los hallazgos técnicos identificados en **example.com** podrían ser aprovechados si no se remedian.

Suplantación de identidad por correo (BEC)		CRÍTICO
El dominio @example.com no tiene DMARC configurado. Sin una política DMARC que instruya al receptor, un tercero puede enviar correo con el dominio example.com en el remitente y los servidores de destino no tienen una señal para rechazarlo.		
Email spoofing → instrucción falsa → acción del destinatario		
IMPACTO OPERACIONAL	IMPACTO REPUTACIONAL	
Correo fraudulento con remitente aparentemente legítimo puede llegar a destinatarios internos y externos. Sin registros DMARC agregados, la organización no tiene visibilidad de los envíos que suplantán su dominio.	Los destinatarios no pueden distinguir un correo suplantado de uno emitido por Example. La confianza en el canal de correo del dominio se degrada para todos sus interlocutores.	

Restricción de origen permisiva (SPF ~all)		MEDIO
El SPF de example.com termina en ~all (softfail): el registro declara qué servidores son legítimos, pero indica al receptor que acepte igualmente el correo de los demás, marcándolo como sospechoso.		
SPF ~all → el receptor acepta correo de origen no autorizado		
IMPACTO OPERACIONAL	IMPACTO REPUTACIONAL	
El correo enviado desde servidores no autorizados puede ser entregado en lugar de rechazado. Cambiar ~all por -all es una modificación de un solo registro DNS.	El correo suplantado puede circular sin ser rechazado en origen.	

Transporte de correo sin cifrar (mail.ejemplo.cl)		ALTO
El servidor de correo mail.ejemplo.cl no ofrece TLS ni STARTTLS. El correo entre servidores viaja en texto plano y puede ser leído o modificado por cualquier actor con acceso a la ruta de red.		
MITM en tránsito SMTP → lectura o modificación sin detección		
IMPACTO OPERACIONAL	IMPACTO REPUTACIONAL	
El contenido de los mensajes y sus adjuntos queda expuesto en tránsito. La modificación en ruta no deja rastro para el receptor.	La correspondencia con terceros circula sin garantía de confidencialidad ni de integridad.	

Plan de Remediación Priorizado

ACCIÓN TÉCNICA	ESFUERZO
Configurar DMARC con política p=reject	MEDIO
Cambiar SPF de ~all a -all	BAJO
Activar TLS/STARTTLS en servidor MX	MEDIO
Esfuerzo agregado	MEDIO

El esfuerzo indicado es una estimacion de trabajo tecnico de configuracion; no incluye validacion ni monitoreo posterior.

Tabla de Hallazgos

ID	SEVERIDAD	HALLAZGO	CATEGORÍA	CVSS	RIESGO DE CONTINUIDAD
VULN-002	CRÍTICA	Registro DMARC ausente ejemplo.cl	Seguridad de correo electrónico	9.0-10.0	BAJO
VULN-003	ALTA	Servidor de correo sin TLS (mail.ejemplo.cl) mail.ejemplo.cl	Configuración TLS/SSL	7.0-8.9	MEDIO
VULN-001	MEDIA	SPF con softfail (~all) — enforcement incompleto ejemplo.cl	Seguridad de correo electrónico	4.0-6.9	BAJO
VULN-005	MEDIA	Panel de administracion expuesto ejemplo.cl	Panel de administración expuesto	4.0-6.9	BAJO
VULN-006	MEDIA	Versión TLS obsoleta habilitada ejemplo.cl	Configuración TLS/SSL	4.0-6.9	MEDIO
VULN-004	BAJA	Cifrado SMTP forzado (MTA-STX) no configurado ejemplo.cl	Seguridad de correo electrónico	0.1-3.9	MEDIO
VULN-007	BAJA	Política HSTS débil o ausente ejemplo.cl	Cabeceras HTTP de seguridad	0.1-3.9	BAJO
GRP-008	INFORMATIVA	Cabeceras HTTP de seguridad (1 hallazgos) ejemplo.cl	Cabeceras HTTP de seguridad	0.0	BAJO
GRP-009	INFORMATIVA	CMS WordPress (1 hallazgos) ejemplo.cl	CMS WordPress	0.0	BAJO

Detalle de Hallazgos

VULN-002		Registro DMARC ausente	CRÍTICA
HOST AFECTADO	CATEGORÍA		
ejemplo.cl	Seguridad de correo electrónico		
CVSS			
9.0–10.0			
¿QUÉ SIGNIFICA ESTE HALLAZGO?			
El dominio no tiene registro DMARC. Cualquier actor puede enviar correos suplantando este dominio sin restricción alguna.			
RECOMENDACIÓN			
Implementar DMARC: v=DMARC1; p=reject; rua=mailto:dmarc@ejemplo.cl			
REFERENCIAS			
https://dmarc.org/overview/			

VULN-003		Servidor de correo sin TLS (mail.ejemplo.cl)	ALTA
HOST AFECTADO	CATEGORÍA		
mail.ejemplo.cl	Configuración TLS/SSL		
CVSS			
7.0–8.9			
¿QUÉ SIGNIFICA ESTE HALLAZGO?			
El servidor de correo mail.ejemplo.cl no tiene TLS habilitado. Los correos entre servidores viajan en texto plano y pueden ser interceptados o modificados, comprometiendo la confidencialidad de las comunicaciones con clientes, proveedores y contrapartes.			
RECOMENDACIÓN			
Habilitar STARTTLS en el servidor de correo. Configurar MTA-STS para forzar TLS en todas las conexiones entrantes.			
REFERENCIAS			
https://www.rfc-editor.org/rfc/rfc3207			

VULN-001SPF con softfail (~all) — enforcement incompleto		MEDIA		
HOST AFECTADO	CATEGORÍA			
ejemplo.cl	Seguridad de correo electrónico			
CVSS				
4.0–6.9				
¿QUÉ SIGNIFICA ESTE HALLAZGO?				
El registro SPF usa ~all (softfail) en lugar de -all (hardfail). Esto permite que servidores no autorizados envíen correos que pueden pasar filtros antispam. Registro actual: v=spf1 include:_spf.example.com ~all				
RECOMENDACIÓN				
Cambiar el mecanismo final de ~all a -all una vez verificadas todas las fuentes legítimas de envío del dominio.				
REFERENCIAS				
https://www.rfc-editor.org/rfc/rfc7208				

VULN-005Panel de administracion expuesto		MEDIA		
HOST AFECTADO	CATEGORÍA			
ejemplo.cl	Panel de administración expuesto			
CVSS				
4.0–6.9				
¿QUÉ SIGNIFICA ESTE HALLAZGO?				
Panel accesible sin restriccion				
RECOMENDACIÓN				
Restringir panel de administración por IP e implementar 2FA.				

VULN-006		Versión TLS obsoleta habilitada	MEDIA
HOST AFECTADO	CATEGORÍA		
ejemplo.cl	Configuración TLS/SSL		
CVSS			
4.0–6.9			
¿QUÉ SIGNIFICA ESTE HALLAZGO?			
TLS obsoleto			
RECOMENDACIÓN			
Actualizar la configuración TLS a 1.2/1.3 únicamente, deshabilitar cipher suites débiles.			

Marco de Cumplimiento Aplicable

OWASP Top 10 (2021)

Categorías de riesgo de seguridad en aplicaciones web mantenidas por la OWASP Foundation. Se usan aquí como marco de referencia técnico para clasificar los hallazgos del reconocimiento pasivo.

<https://owasp.org/Top10/>

CONTROL	HALLAZGOS
A01:2021 — Broken Access Control Paneles de administracion alcanzables desde internet. Panel de administración expuesto	1
A02:2021 — Cryptographic Failures Ausencia de TLS, protocolos obsoletos o certificados invalidos en los servicios expuestos. Configuración TLS/SSL · Seguridad de correo electrónico	3
A05:2021 — Security Misconfiguration Cabeceras HTTP de seguridad ausentes o mal configuradas. Cabeceras HTTP de seguridad	2
A06:2021 — Vulnerable and Outdated Components CMS WordPress	1
A07:2021 — Identification and Authentication Failures La ausencia de DMARC permite suplantar la identidad del dominio en el canal de correo. Seguridad de correo electrónico	2

ALCANCE Y LIMITACIONES

Análisis realizado exclusivamente mediante técnicas OSINT y reconocimiento pasivo de superficie, sin acceso a sistemas internos, bases de datos ni código fuente. Los hallazgos reflejan el estado de la infraestructura pública en la fecha de análisis. El mapeo a controles es orientativo y no constituye una certificación de cumplimiento.

CROWSNEST

PASSIVE RECONNAISSANCE

La seguridad no es un estado. Es un proceso.

Los hallazgos de este informe reflejan la superficie expuesta en la fecha de análisis. La remediación de un hallazgo no elimina la necesidad de reevaluar: la superficie cambia con cada despliegue, cada servicio nuevo y cada cambio de DNS.

PRÓXIMOS PASOS

Revisión de hallazgos críticos
Plan de remediación priorizado
Reevaluación periódica de superficie

ALCANCE

Reconocimiento pasivo
Sin pruebas activas
Sin acceso a sistemas internos